

Information Security Management System Audit

Organization	Helios Cloud Services Ltd.
Site / scope	Headquarters + EU-West data centre (Dublin)
Lead auditor	M. Laurent (Lead Auditor, IRCA cert. 2024-LA-3187)
Audit team	S. Okafor (auditor), A. Bianchi (technical expert – cloud)
Audit date	13 May 2026
Standard	ISO/IEC 27001:2022 (cl. 4–10) + Annex A controls referenced via SoA
Report generated	2026-05-13
Report ref.	AUD-ISMS-2026-01

1. Executive Summary

This internal audit assessed conformity of Helios Cloud Services Ltd.'s information security management system against ISO/IEC 27001:2022, clauses 4–10, with reference to the Statement of Applicability covering the Annex A controls. The audit covered 25 management-system clauses across all ISMS scope. Overall conformity rate is **80%**. **1 Major nonconformity** requires prompt corrective action (see Section 4). 2 Minor NCs and 2 Opportunities for Improvement were also raised. The ISMS is broadly effective; the most material weakness relates to overdue treatment of High-residual risks (clause 8.3).

Conformant	OFI	Minor NC	Major NC	N/A	Conformity
20	2	2	1	0	80%

2. Audit Objectives, Scope and Methodology

Objectives. Determine the extent of conformity of the ISMS with ISO/IEC 27001:2022 requirements; evaluate the ability of the ISMS to ensure the organization meets applicable legal, regulatory and contractual information-security requirements; and identify opportunities for improvement.

Scope. All ISMS processes within the certified scope (HQ and EU-West data centre, HelioOps SaaS platform). Annex A controls assessed by sampling, traced through the SoA.

Methodology. Document review, interviews with control owners (CISO, SecOps lead, IT Manager, HR Manager, Procurement Lead, DPO), walk-throughs of incident response, change management, access provisioning, vulnerability management and supplier on-boarding, and sample testing of records (n=55 across processes).

Classification of findings. *Major NC* — failure of a system requirement that puts conformity at risk; *Minor NC* — isolated lapse not affecting overall conformity; *OFI* — opportunity for improvement, no NC raised.

3. Annex A control themes (referenced via SoA)

Theme	Name	Controls	Examples
A.5	Organizational	37	policies, roles, threat intel, supplier security, incident management
A.6	People	8	screening, terms of employment, awareness, disciplinary, remote working
A.7	Physical	14	perimeter, entry, secure areas, equipment, cabling, secure disposal

A.8	Technological	34	access control, cryptography, secure development, logging, network, malware, backup
-----	---------------	----	---

4. Clause Coverage

Clause	Title	Status
4.1	Understanding the organization and its context	Conformant
4.2	Needs and expectations of interested parties	Conformant
4.3	Determining the scope of the ISMS	Conformant
4.4	Information security management system	Conformant
5.1	Leadership and commitment	Conformant
5.2	Information security policy	OFI
5.3	Organizational roles, responsibilities and authorities	Conformant
6.1.1	Actions to address risks and opportunities — General	Conformant
6.1.2	Information security risk assessment	Minor NC
6.1.3	Information security risk treatment & SoA	Conformant
6.2	Information security objectives and planning	Conformant
6.3	Planning of changes	Conformant
7.1	Resources	Conformant
7.2	Competence	Conformant
7.3	Awareness	OFI
7.4	Communication	Conformant
7.5	Documented information	Conformant
8.1	Operational planning and control	Conformant
8.2	Information security risk assessment (operational)	Conformant
8.3	Information security risk treatment (operational)	Major NC
9.1	Monitoring, measurement, analysis and evaluation	Conformant
9.2	Internal audit	Conformant
9.3	Management review	Conformant
10.1	Continual improvement	Conformant
10.2	Nonconformity and corrective action	Minor NC

5. Detailed Findings

F-001 · OFI · Clause 5.2 — Information security policy

Status	OFI
Clause	5.2 — Information security policy
Evidence reviewed / observations	Policy POL-IS-01 rev.6 dated Jan-2026, communicated via intranet & induction.
Finding statement	OFI-001: Policy does not explicitly reference NIS2 obligations introduced in Q1-2026. Recommend update at next planned review.
Requirement	ISO/IEC 27001:2022 — see clause referenced above
Owner	CISO (to assign)
Containment / correction (proposed)—	
Root-cause analysis due	Within 14 days of report acceptance
Corrective action due	Within 60 days (Minor / OFI) · 30 days (Major)
Effectiveness verification	At next surveillance audit or earlier (Major)

F-002 · Minor NC · Clause 6.1.2 — Information security risk assessment

Status	Minor NC
Clause	6.1.2 — Information security risk assessment
Evidence reviewed / observations	Risk methodology RM-IS-02 defines criteria; sampled 10 risks (R-014 to R-023).
Finding statement	Minor-001: 3 of 10 sampled risks (R-016, R-019, R-022) had no documented risk-owner approval after the last update (Feb-2026), contrary to RM-IS-02 §5.4. Requirement: ISO/IEC 27001:2022 cl. 6.1.2(c).
Requirement	ISO/IEC 27001:2022 — see clause referenced above
Owner	CISO (to assign)
Containment / correction (proposed)—	
Root-cause analysis due	Within 14 days of report acceptance
Corrective action due	Within 60 days (Minor / OFI) · 30 days (Major)
Effectiveness verification	At next surveillance audit or earlier (Major)

F-003 · OFI · Clause 7.3 — Awareness

Status	OFI
Clause	7.3 — Awareness
Evidence reviewed / observations	Annual awareness 100% completion; quarterly phishing simulation (Q1 fail rate 3.2%).
Finding statement	OFI-002: Awareness for non-technical contractors is delivered at induction only — recommend annual refresher to match the employee programme.
Requirement	ISO/IEC 27001:2022 — see clause referenced above
Owner	CISO (to assign)
Containment / correction (proposed)—	
Root-cause analysis due	Within 14 days of report acceptance
Corrective action due	Within 60 days (Minor / OFI) · 30 days (Major)
Effectiveness verification	At next surveillance audit or earlier (Major)

F-004 · Major NC · Clause 8.3 — Information security risk treatment (operational)

Status	Major NC
Clause	8.3 — Information security risk treatment (operational)
Evidence reviewed / observations	Risk-treatment plan RTP-2026 — 42 actions, 31 closed, 11 open.
Finding statement	Major-001: 4 of the 11 open risk-treatment actions (RTP-2026-07, -12, -19, -28) addressing High residual risks are >90 days overdue with no documented re-acceptance by the risk owner. Requirement: ISO/IEC 27001:2022 cl. 8.3 (treatment plan implementation) and cl. 6.1.3(f) (residual-risk acceptance).
Requirement	ISO/IEC 27001:2022 — see clause referenced above
Owner	CISO (to assign)
Containment / correction (proposed)—	
Root-cause analysis due	Within 14 days of report acceptance
Corrective action due	Within 60 days (Minor / OFI) · 30 days (Major)
Effectiveness verification	At next surveillance audit or earlier (Major)

F-005 · Minor NC · Clause 10.2 — Nonconformity and corrective action

Status	Minor NC
Clause	10.2 — Nonconformity and corrective action
Evidence reviewed / observations	CAPA procedure CAPA-01; sampled 8 NCs from last 12 months.
Finding statement	Minor-002: 2 of 8 sampled corrective actions (CAPA-2025-19, CAPA-2026-04) closed without documented effectiveness verification. Requirement: ISO/IEC 27001:2022 cl. 10.2(d).
Requirement	ISO/IEC 27001:2022 — see clause referenced above
Owner	CISO (to assign)
Containment / correction (proposed)—	
Root-cause analysis due	Within 14 days of report acceptance
Corrective action due	Within 60 days (Minor / OFI) · 30 days (Major)
Effectiveness verification	At next surveillance audit or earlier (Major)

6. Audit Conclusions

The ISMS of Helios Cloud Services Ltd. is, in the opinion of the audit team, suitable, adequate and broadly effective in achieving its intended outcomes, with the exception of the Major nonconformity raised against clause 8.3 (overdue High-residual risk-treatment actions). Closure of this Major NC, together with the 2 Minor NCs, is required before the next external surveillance audit (scheduled Q4-2026). The 2 OFIs are recommendations and do not affect conformity.

The audit found particular strengths in: (i) management commitment and resourcing, (ii) the maturity of the monitoring and measurement programme (clause 9.1), and (iii) the integration of incident learnings into the improvement register (clause 10.1).

7. Approval

Prepared by (Lead Auditor)	M. Laurent (Lead Auditor, IRCA cert. 2024-LA-3187) Date: 2026-05-13
Reviewed by (CISO)	_____ Date: _____
Acknowledged by (Auditee)	_____ Date: _____